CSIT5730: Introduction & Security Mindset

Shuai Wang

香港科技大學
THE HONG KONG UNIVERSITY OF SCIENCE AND TECHNOLOGY

Course Information

- CSIT5730: Principles of Cybersecurity
  - We will meet every Thu 19:30 - 22:20, Room 4619.
  - In person mode during the semester
  - RVC recording can share with you
    - RVC recording will be ready a few hours after the lecture, typically.
  - Feel free to let me know whenever you have question during the lecture ☺

Course Information

- CSIT5730: Principles of Cybersecurity
  - We will meet every Thu 19:30 - 22:20, Room 4619.

- Time allocation:
  - Every lecture time, we will have about 15 mins break (roughly at 8:50~9:05).
  - Feel free to drink water and have a rest (both you and me) 😇
  - We will have a dedicated time for Q&A --- 10~15 mins before the end of the lecture time. Also, right after the lecture time.

Course Information

- Background survey
  - How many of you have non-trivial experiences in C/C++? // it's totally fine if you don't!
  - How many of you have taken computer security courses in undergraduate?
  - How many of you have played/mastered CTF before?
  - How many of you have co-authored/published research papers in security conferences/journals like USENIX Security, CCS, IEEE S&P, and NDSS?
- Course setup clarification:
  - This course aims to serve as a PG-level, introduction course of cybersecurity.
    - Perhaps we'll have a cybersecurity masters program in a few years later, and this course will become the "101" course in that program.
  - With today's survey results, I will consider adjusting the course content/difficulty wisely.

Who am I?

- Instructor: Shuai Wang
  - Associate Professor of CSE at HKUST (now)
  - Assistant Professor of CSE at HKUST (19~24)
  - Postdoc Scholar at ETH Zurich (18~19)
  - PhD at Penn State University (13~18)
  - B.S. at Peking University (08~12)
- Research Interests:
  - Cybersecurity
  - Software Engineering
  - *Particularly cracking systems and software under various scenarios.*
- Office:
  - Room 3516
  - Office hour: by appointment
  - Let me know your feedback

TA & Tutorial Sessions & Contact Info

- TA: Dr. Huaijin WANG
- Office: Cybersecurity Lab (Room 3664, Lift 31-32)
- Please preface your e-mail title with “[CSIT5730]”
  - Shuai Wang: shuaiw@cse.ust.hk
  - Sen Deng: huaijinwang@ust.hk

Course Website

- Course site: https://home.cse.ust.hk/~shuaiw/Password_Only/CSIT5730/
  - Account: csit_student
  - PWD: csit2025student
- Please make sure you can access the course site
- Schedule is tentatively posted:
  - Please frequently check this web-page for any schedule changes → I will also announce in the class
  - We will have a slow start but become slightly faster later.

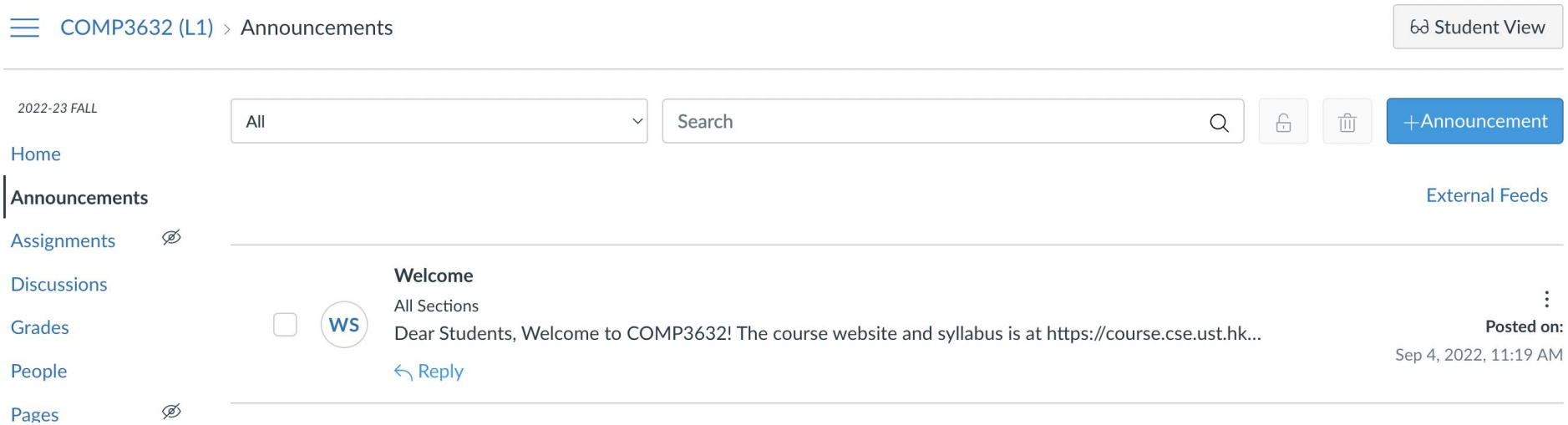
Class Schedule

Below is the calendar for this semester course. This is the preliminary schedule, which will be altered as the semester progresses. It is the responsibility of the students to frequently check this web-page for schedule, readings, and assignment changes. As the professor, I will attempt to announce any change to the class, but this web-page should be viewed as authoritative. If you have any questions, please contact me.

Date	Topic	Readings/Notes/Homework	Misc.
05/09	Introduction; Security Mindset | Classic Crypto | Slides	A Contemporary Look at Saltzer and Schroeder's 1975 Design Principles. link. notes	
12/09	Symmetric Key Crypto | Slides	Stream Ciphers: Dead or Alive? link. Chapter 2; 3 of the first textbook. Limitations of the Even-Mansour Construction Introduction to Authenticated Encryption. link. AES Sample Code notes	HW1 release
19/09	Public Key Crypto | Slides	Chapter 4 and 5 of the first textbook. Notes RSA Correctness Proof Hash Collision Estimation Proof	

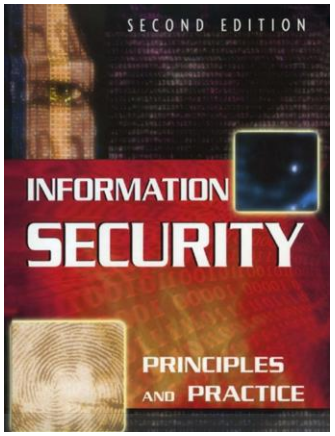
Canvas

- We use Canvas for homework submission and make announcement

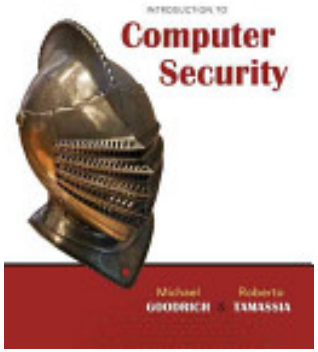


Slides & Textbook

- Will post on the course website before the class
  - Will post hand-written notes after each class
- Readings are optional, encourage to read after the class.
- Textbook (optional):



Information Security: Principles and Practice



Introduction to Computer Security

Again, for textbooks, they are not required; E-book is fine.

Grading

- In-class quizzes – 8% // no in-class quiz during the add/drop period
  - Right before the end of certain lectures, I will allocate 10~15 mins for a few very easy questions.
- Assignment (x3) – 12%
  - Written + Programming (for the 2nd assignment)
- Midterm exam – 20%
  - Oct. 9th
  - during the lecture time;
  - Topics taught for the first half of the course
- Final exam – 35%
  - TBD
- Group projects
  - I plan to announce the details on Oct. 9th, right after the mid-term.
  - Will need to see the #students in the class and adjust accordingly.

*If any student needs special accommodations because of a disability, please contact me in the first two weeks of classes

Policies

- Late policy
  - All homework assignments are assessed a 20% per-day late penalty, up to a maximum of 3 days.
- Assignment
  - Assignments have to be complete by the student individually.
  - The student will receive the same penalty if he/she let others copy the assignment.
- Classroom
  - Using laptops are allowed in class.
- Ethics statement
  - Be a happy and ethic hacker ☺
  - More in course website. You can always reach out to me and ask.

Questions?

Goals for this Course

- Inter-discipline + real-world problem driven.
- Mindset
  - How to think like an attacker/defender
  - How to reason about threats and risks
- Principles & Technical Skills
  - How to design and program secure software
  - How to secure private data
  - …
- Get some senses on the "problem-driven" style studies in cybersecurity
  - It's always an arms race, between attackers and defenders
- Learn to become a "hacker", an ethic one

Cybersecurity is Real-World Problem-Driven

- Although we mostly focus on principle in this course.
- Many (research) topics are indeed driven by security breaches in the real world!
  - That's one key reason I decide to work in this field

And lack of security sense can cause you a big trouble, as you will see in the next slide…

A True (sad?) Story

aws

Amazon Web Services

Mon May 18 2020 10:51:26

Translate

Was this response helpful? Click here to rate:

Hi there,

wangshuai

Hello,

aws

Amazon Web Services

Fri Jun 05 2020 15:00:49 GMT+0800 (Hong Kong Standard Time)

Translate

Was this response helpful? Click here to rate:

Hello there,

Martin here from AWS.

I'm happy to advise that 100% of the charges for the compromised activity on your account has been waived. Rest assured, you no longer have to worry about the charges.

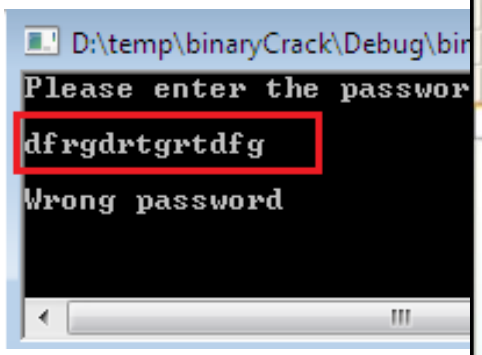
To avoid similar compromises in the future, please consider the following to help improve the security of your account.

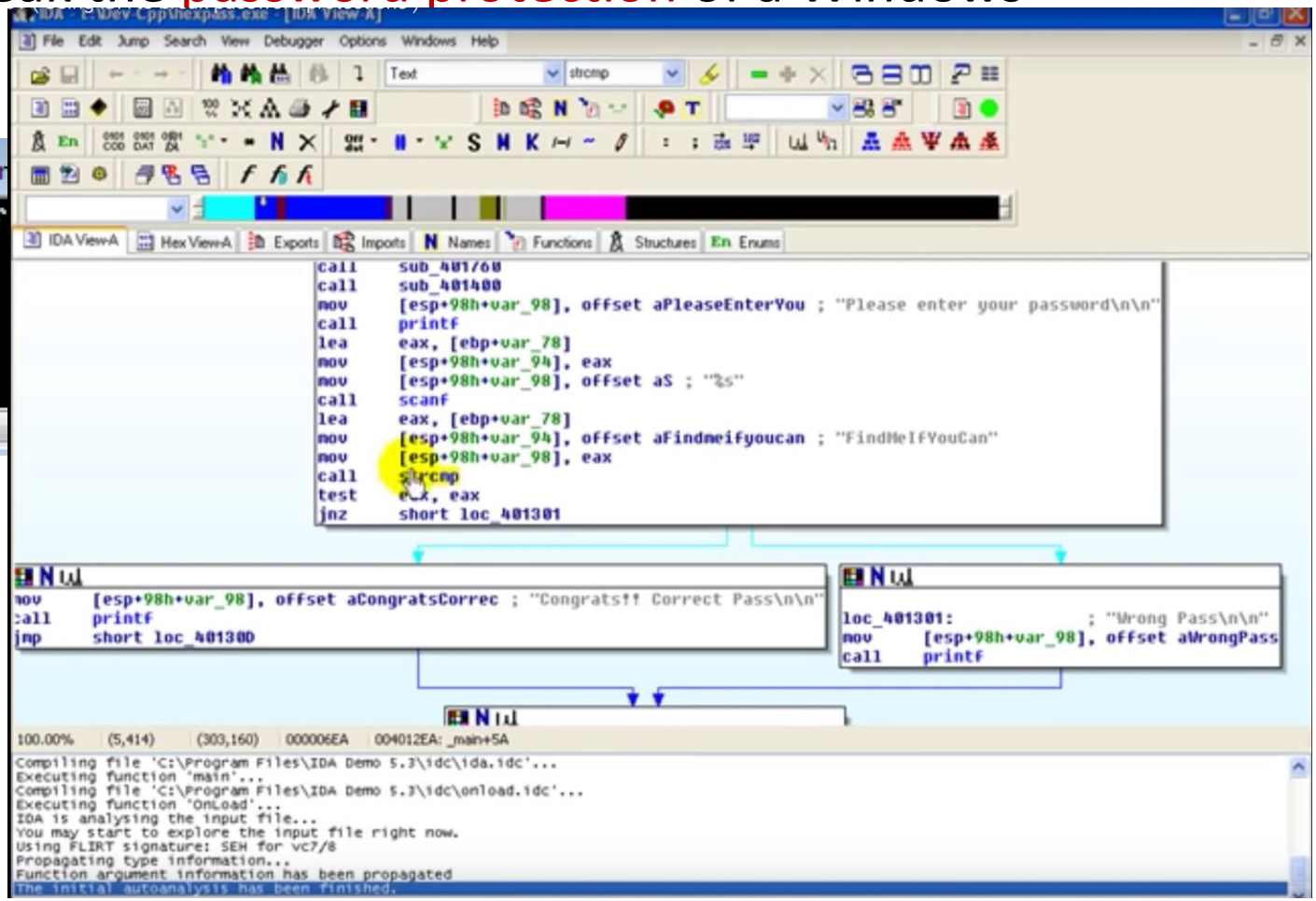
Topics Covered in This Course

- Security basics and definitions:
  - Confidentiality, Integrity, Availability, attack models
- Cryptography:
  - Basic crypto primitives, public key crypto, signatures, authentication, symmetric crypto
- Software security:
  - Memory errors, buffer overflow, obfuscation, malware, security testing
- System & web security:
  - Authentication, access control, protocols, browser security, side channel attacks
- Security on emerging platforms:
  - blockchain; smart contracts; AI;

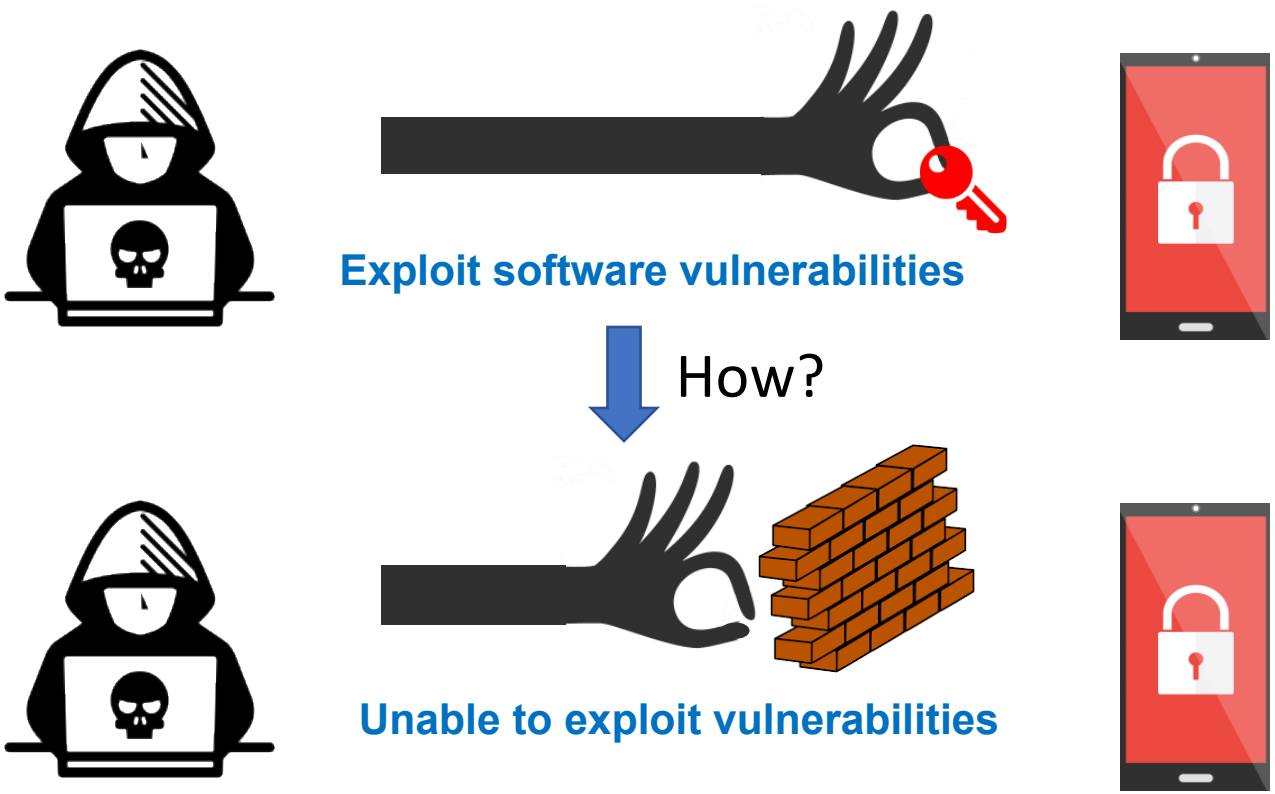
Reverse Engineering

- How to break the password protection of a Windows software?



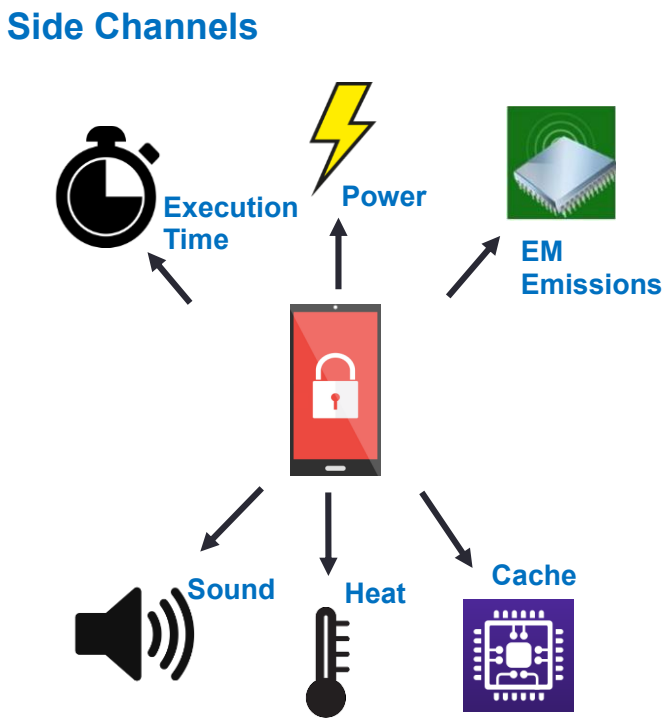


Side Channel Attacks



Side Channel Attacks

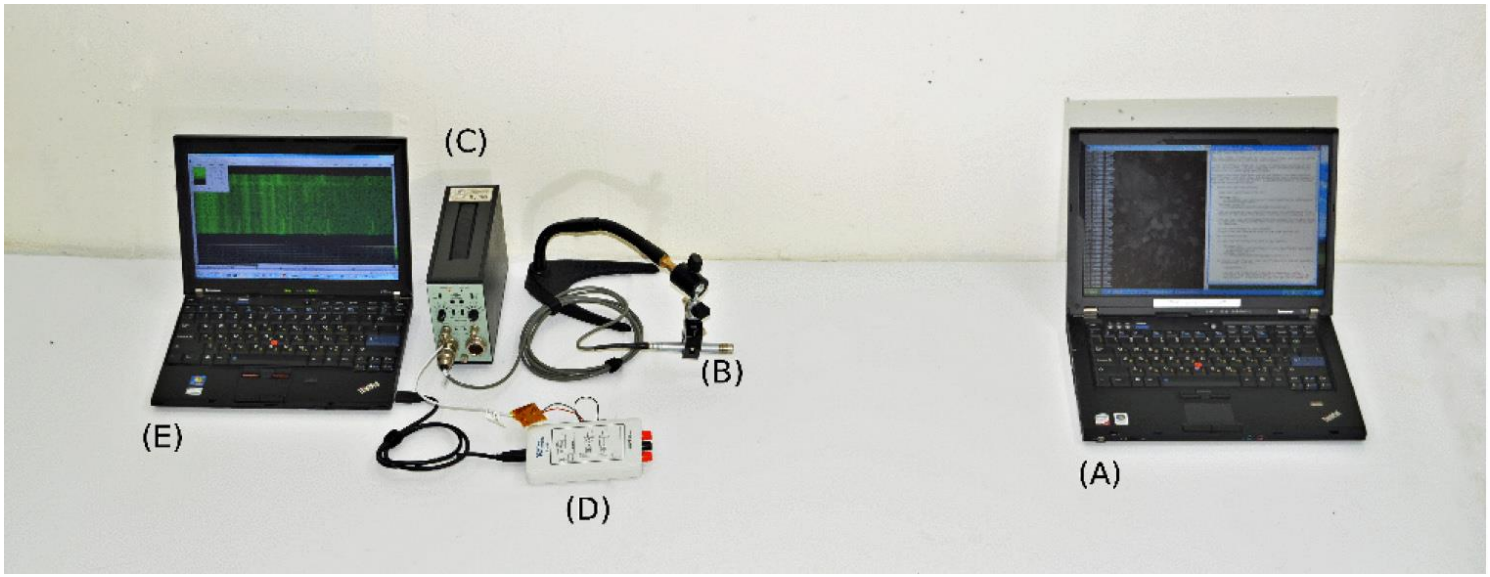
- De-facto exploitations in Cybersecurity



Infer secrets via **secret-dependent** physical information.

Side Channel Attacks

- Infer your secrets (password; private key) via acoustic side channel attack

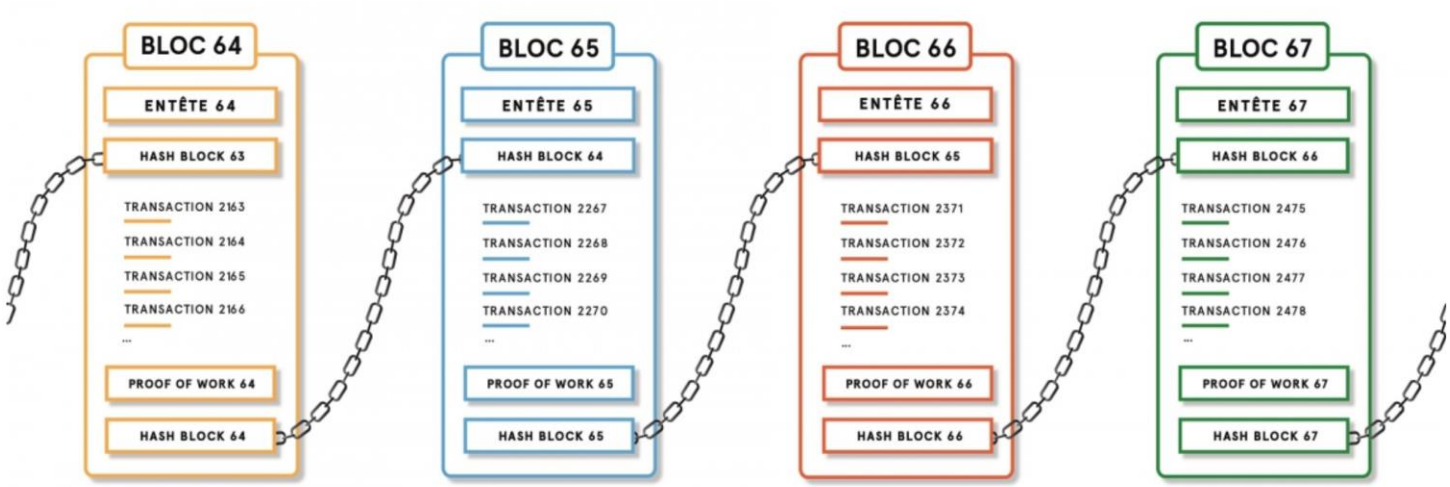


Attacker's

Victim's

Blockchain

The best real-world crypto application ~~and have made many millionaires~~?



Bitcoin

- Unregulated digital currency
- Bitcoin transactions are stored on Blockchain
- Each anonymous address on the blockchain acted as a simple bank account.

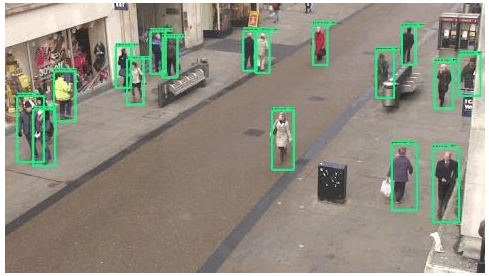
Ethereum

- Unregulated digital currency and computing system
- Smart contracts: programs executed on the blockchain
- Each anonymous address on the blockchain could be a user or a smart contract.

Blockchain figure from: https://blog.theodo.com/2018/01/deploy-first-ethereum-smart-contract-blockchain/

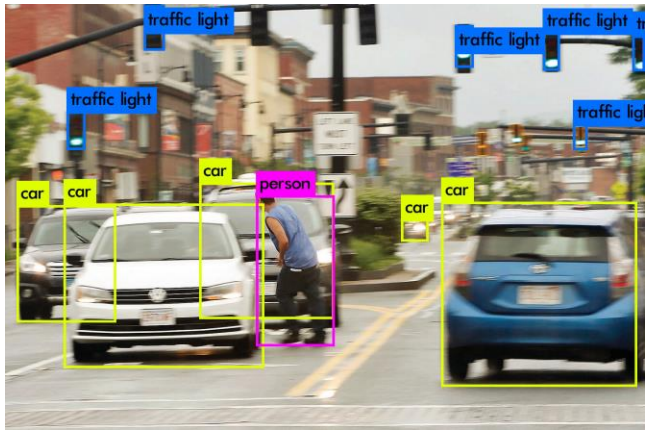
Artificial Intelligence

- AI techniques have been used for security purposes.

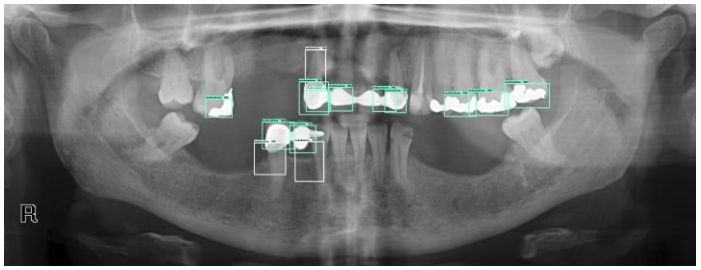


Surveillance Camera

Surveillance Camera



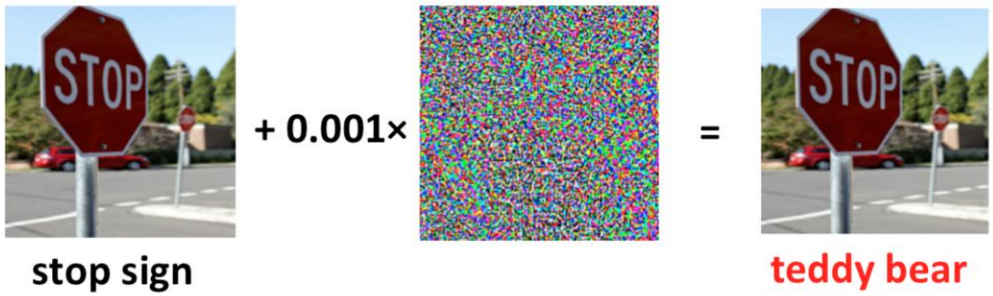
Auto-Driving Systems



Medical Image Processing

Artificial Intelligence

- Adversarial attacks are popular...



Classification failure

Object detection failure

We will talk more cases on AI security.

Questions?

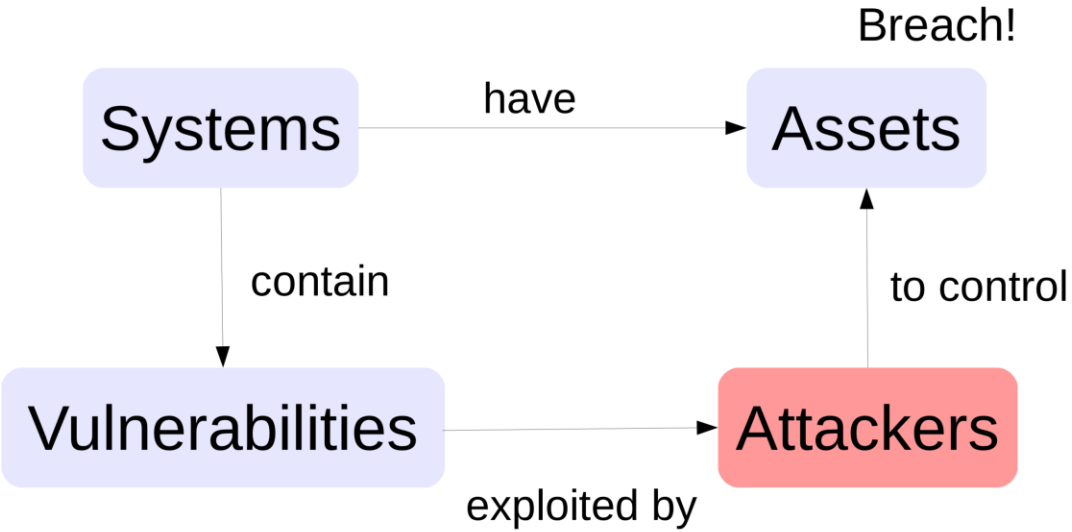
The Security Mindset

Attacker vs. defender

The Security Mindset

- Think like a cyber attacker
  - Understand techniques and opportunities for exploiting security. → next two slides
- Think like a cyber defender
  - Know yourself: security policy
  - Know yourself: risk assessment
  - Know your enemy: threat model
  - Benefits vs. costs:
    - Some security defenses are just too expensive

Think Like an Attacker



Think Like an Attacker

Where do vulnerabilities come from?

Vulnerabilities

Design

- Theoretical limitations
- Lack of security features (e.g. authentication)
- Side channels
- Wrong threat model
- Wrong user model

Implementation

- Coding errors
- Hardware errors
- Injected errors
- Failure to meet specifications

Where can I get vulnerabilities?

- Find unknown vulnerabilities → hard
- Buy zero-day vulnerabilities → well, you can do that..?
- Reuse known vulnerabilities → easy?

But Why Good Citizens Need to Know How to Attack?

To understand this, think about why biologists would study (unknown) virus...

White hat wizards!

- Identify vulnerabilities so they can be fixed.
- Learn about unknown threats.
- Help venders to build more secure systems.
- ~~And get lots of bonus from vendors~~

Think Like a Defender

- Security policy
  - What property we are trying to enforce?
    - E.g., password can only be stored within my phone.
    - E.g., data pointers in your C code can only access certain memory region.
  - Could be difficult to even define the policy/specification
- Risk assessment
  - Identify assets (e.g., network, servers, applications, data centers, etc.) within the organization.
  - Asset criticality.
  - Measure the risk ranking for assets and prioritize them for assessment.

Think Like a Defender

- Threat model
  - Who are the attackers?
  - What kind of capability they have?
  - What kind of information/data they try to steal?

Think Like a Defender

- Threat model for a (simplified) cloud computing platform
  - Attacker; capability; assets

Think Like a Defender

- Threat model
  - Who are the attackers?
    - Service provider, and other users
  - What kind of capability they have?
    - Service provider can control anything
    - Attackers on the cloud VM can share the same hardware with you
      - Common threat model for side channels
  - What kind of assets they try to steal?
    - Anything valuable!

Think Like a Defender

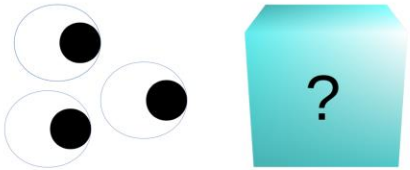
- Costs vs. benefits?
  - For example, to protect an OS kernel from being exploited, you can have two options:
    - Online monitoring:
      - easy to do.
      - slow down the performance
    - Offline formal verification:
      - very difficult to conduct for commercial OS.
      - But no penalty for online performance.
- Saltzer and Schroeder's Principles of Secure Design
  - A series of design principles for secure systems
    - Extensions for reading after the class.
  - Some of the rules may not be applicable nowadays.

Saltzer and Schroeder's Principles of Secure Design

- 1) Open Design vs. Obscure Design

The system's design should be openly available to everyone.

"Given enough eyeballs, all bugs are shallow"
-- Linus Torvalds



Saltzer and Schroeder's Principles of Secure Design

- 2) Economy of Mechanism

The system should be simple enough to understand and analyze.

Helpful for security analysis:
- Debugging/code audit
- Static/dynamic analysis
- Formal verification

Clean interfaces between modules, avoid global state, etc.

Saltzer and Schroeder's Principles of Secure Design

- 3) Least Privilege

A subject should only be given the minimum necessary privileges for completing its task.

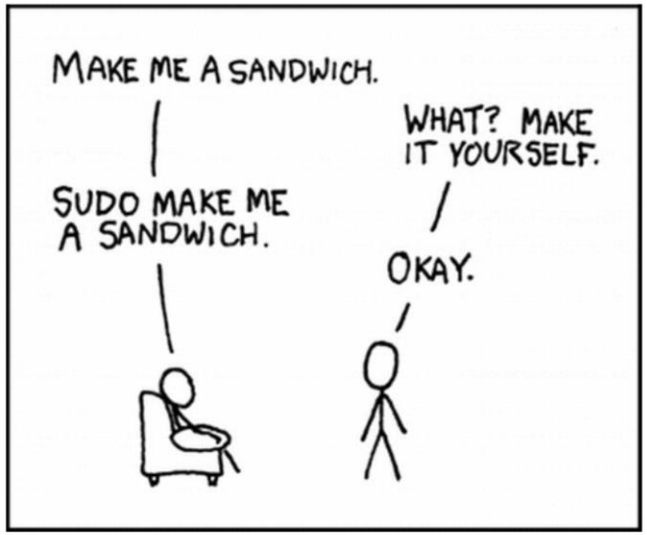


Figure out exactly what capabilities a program requires in order to run, and grant exactly those

- This is not easy. One approach is to start with granting none, and see where errors occur.

Principles of CIA

Confidentiality

Information is secret

Integrity

Information/System is correct

Availability

System is usable

We will talk more on these aspects later.

Summary

- The endless arms race between cyber attackers and defenders lead to many interesting problems
  - For doing research & engineering
- Be a happy and ethic hacker!
  - Otherwise your instructor might run into trouble …
  - Whenever in doubt, ask me